

CVEs más relevantes de la semana

Del 31/03/2026 al 07/04/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-24148

Descripción: NVIDIA Jetson for JetPack contains a vulnerability in the system initialization logic, where an unprivileged attacker could cause the initialization of a resource with an insecure default. A successful exploit of this vulnerability might lead to information disclosure of encrypted data, data tampering, and partial denial of service across devices sharing the same machine ID.

CVSS: 8.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:L

Tipo: CWE-1188

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-24164

Descripción: NVIDIA BioNeMo contains a vulnerability where a user could cause a deserialization of untrusted data. A successful exploit of this vulnerability might lead to code execution, denial of service, information disclosure, and data tampering.

CVSS: 8.8 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-34359

Descripción: HAPI FHIR is a complete implementation of the HL7 FHIR standard for healthcare interoperability in Java. Prior to version 6.9.4, ManagedWebAccessUtils.getServer() uses String.startsWith() to match request URLs against configured server URLs for authentication credential dispatch. Because configured server URLs (e.g., http://tx.fhir.org) lack a trailing slash or host boundary check, an attacker-...

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-346

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-34361

Descripción: HAPI FHIR is a complete implementation of the HL7 FHIR standard for healthcare interoperability in Java. Prior to version 6.9.4, the FHIR Validator HTTP service exposes an unauthenticated `/loadIG` endpoint that makes outbound HTTP requests to attacker-controlled URLs. Combined with a `startsWith()` URL prefix matching flaw in the credential provider (`ManagedWebAccessUtils.getServer()`), an attack...

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:L/A:N

Tipo: CWE-552

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-4800

Descripción: Impact:

The fix for CVE-2021-23337

(<https://github.com/advisories/GHSA-35jh-r3h4-6jhm>) added validation for the variable option in `_.template` but did not apply the same validation to `options.imports` key names. Both paths flow into the same `Function()` constructor sink.

When an application passes untrusted input as `options.imports` key names, an attacker can inject default-parameter expressions ...

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2025-71279

Descripción: XenForo before 2.3.7 contains a security issue affecting Passkeys that have been added to user accounts. An attacker may be able to compromise the security of Passkey-based authentication.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-04-01



CVE-2025-71281

Descripción: XenForo before 2.3.7 does not properly restrict methods callable from within templates. A loose prefix match was used instead of a stricter first-word match for methods accessible through callbacks and variable method calls in templates, potentially allowing unauthorized method invocations.

CVSS: 8.8 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-04-01



CVE-2026-5256

Descripción: A flaw has been found in code-projects Simple Laundry System 1.0. This vulnerability affects unknown code of the file /modify.php of the component Parameter Handler. This manipulation of the argument firstName causes sql injection. Remote exploitation of the attack is possible. The exploit has been published and may be used.

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-04-01



CVE-2026-5257

Descripción: A vulnerability has been found in code-projects Simple Laundry System 1.0. This issue affects some unknown processing of the file /delstaffinfo.php of the component Parameter Handler. Such manipulation of the argument userid leads to sql injection. The attack can be executed remotely. The exploit has been disclosed to the public and may be used.

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-04-01



CVE-2026-34430

Descripción: ByteDance Deer-Flow versions prior to commit 92c7a20 contain a sandbox escape vulnerability in bash tool handling that allows attackers to execute arbitrary commands on the host system by bypassing regex-based validation using shell features such as directory changes and relative paths. Attackers can exploit the incomplete shell semantics modeling to read and modify files outside the sandbox bo...

CVSS: 8.8 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Tipo: CWE-184

Tecnología: No especificado

Publicado el: 2026-04-01



CVE-2026-20093

Descripción: A vulnerability in the change password functionality of Cisco Integrated Management Controller (IMC) could allow an unauthenticated, remote attacker to bypass authentication and gain access to the system as Admin. This vulnerability is due to incorrect handling of password change requests. An attacker could exploit this vulnerability by sending a crafted HTTP request to an affected devi...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-04-01



CVE-2026-20160

Descripción: A vulnerability in Cisco Smart Software Manager On-Prem (SSM On-Prem) could allow an unauthenticated, remote attacker to execute arbitrary commands on the underlying operating system of an affected SSM On-Prem host. This vulnerability is due to the unintentional exposure of an internal service. An attacker could exploit this vulnerability by sending a crafted request to the API of the e...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-668

Tecnología: No especificado

Publicado el: 2026-04-01



CVE-2026-34528

Descripción: File Browser is a file managing interface for uploading, deleting, previewing, renaming, and editing files within a specified directory. Prior to version 2.62.2, the signupHandler in File Browser applies default user permissions via d.settings.Defaults.Apply(user), then strips only Admin. The Execute permission and Commands list from the default user template are not stripped. When an administr...

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-269

Tecnología: No especificado

Publicado el: 2026-04-01



CVE-2026-34529

Descripción: File Browser is a file managing interface for uploading, deleting, previewing, renaming, and editing files within a specified directory. Prior to version 2.62.2, the EPUB preview function in File Browser is vulnerable to Stored Cross-Site Scripting (XSS). JavaScript embedded in a crafted EPUB file executes in the victim's browser when they preview the file. This issue has been patched in versio...

CVSS: 7.6 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:L/A:N

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-04-01



CVE-2026-4101

Descripción: IBM Verify Identity Access Container 11.0 through 11.0.2 and IBM Security Verify Access Container 10.0 through 10.0.9.1 and IBM Verify Identity Access 11.0 through 11.0.2 and IBM Security Verify Access 10.0 through 10.0.9.1 under certain load conditions could allow an attacker to bypass authentication mechanisms and gain unauthorized access to the application.

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-04-01



CVE-2026-34565

Descripción: CI4MS is a CodeIgniter 4-based CMS skeleton that delivers a production-ready, modular architecture with RBAC authorization and theme support. Prior to version 0.31.0.0, the application fails to properly sanitize user-controlled input when adding Posts to navigation menus through the Menu Management functionality. Post-related data selected via the Posts section is stored server-side and rendere...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:L

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-04-01



CVE-2026-34566

Descripción: CI4MS is a CodeIgniter 4-based CMS skeleton that delivers a production-ready, modular architecture with RBAC authorization and theme support. Prior to version 0.31.0.0, the application fails to properly sanitize user-controlled input within the Page Management functionality when creating or editing pages. Multiple input fields accept attacker-controlled JavaScript payloads that are stored serve...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:L

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-04-01



CVE-2026-34567

Descripción: CI4MS is a CodeIgniter 4-based CMS skeleton that delivers a production-ready, modular architecture with RBAC authorization and theme support. Prior to version 0.31.0.0, the application fails to properly sanitize user-controlled input when creating or editing blog posts within the Categories section. An attacker can inject a malicious JavaScript payload into the Categories content, which is then...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:L

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-04-01



CVE-2026-34568

Descripción: CI4MS is a CodeIgniter 4-based CMS skeleton that delivers a production-ready, modular architecture with RBAC authorization and theme support. Prior to version 0.31.0.0, the application fails to properly sanitize user-controlled input when creating or editing blog posts. An attacker can inject a malicious JavaScript payload into blog post content, which is then stored server-side. This stored pa...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:L

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-04-01



CVE-2026-34569

Descripción: CI4MS is a CodeIgniter 4-based CMS skeleton that delivers a production-ready, modular architecture with RBAC authorization and theme support. Prior to version 0.31.0.0, the application fails to properly sanitize user-controlled input when creating or editing blog categories. An attacker can inject a malicious JavaScript payload into the category title field, which is then stored server-side. Th...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-04-01



CVE-2026-34571

Descripción: CI4MS is a CodeIgniter 4-based CMS skeleton that delivers a production-ready, modular architecture with RBAC authorization and theme support. Prior to version 0.31.0.0, a Stored Cross-Site Scripting (Stored XSS) vulnerability exists in the backend user management functionality. The application fails to properly sanitize user-controlled input before rendering it in the administrative interface, ...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-04-01



CVE-2026-33615

Descripción: An unauthenticated remote attacker can exploit an unauthenticated SQL Injection vulnerability in the setinfo endpoint due to improper neutralization of special elements in a SQL UPDATE command. This can result in a total loss of integrity and availability.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-04-02



CVE-2026-5334

Descripción: A weakness has been identified in itsourcecode Online Enrollment System 1.0. Impacted is an unknown function of the file /enrollment/index.php?view=edit&id=3 of the component Parameter Handler. This manipulation of the argument deptid causes sql injection. The attack is possible to be carried out remotely. The exploit has been made available to the public and could be used for attacks.

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-04-02



CVE-2026-32213

Descripción: Improper authorization in Azure AI Foundry allows an unauthorized attacker to elevate privileges over a network.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-285

Tecnología: No especificado

Publicado el: 2026-04-03



CVE-2026-33105

Descripción: Improper authorization in Microsoft Azure Kubernetes Service allows an unauthorized attacker to elevate privileges over a network.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-285

Tecnología: No especificado

Publicado el: 2026-04-03



CVE-2026-33107

Descripción: Server-side request forgery (ssrf) in Azure Databricks allows an unauthorized attacker to elevate privileges over a network.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-04-03



CVE-2026-32186

Descripción: Server-side request forgery (ssrf) in Microsoft Bing allows an unauthorized attacker to elevate privileges over a network.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-04-03



CVE-2017-20237

Descripción: Hirschmann Industrial HiVision versions prior to 06.0.07 and 07.0.03 contains an authentication bypass vulnerability in the master service that allows unauthenticated remote attackers to execute arbitrary commands with administrative privileges. Attackers can invoke exposed interface methods over the remote service to bypass authentication and achieve remote code execution on the underlying ope...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-04-03



CVE-2018-25237

Descripción: Hirschmann HiSecOS devices versions prior to 05.3.03 contain a buffer overflow vulnerability in the HTTPS login interface when RADIUS authentication is enabled that allows remote attackers to crash the device or execute arbitrary code by submitting a password longer than 128 characters. Attackers can exploit improper bounds checking in password handling to overflow a fixed-size buffer and achie...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-120

Tecnología: No especificado

Publicado el: 2026-04-03



CVE-2017-20234

Descripción: GarrettCom Magnum 6K and 10K managed switches contain an authentication bypass vulnerability that allows unauthenticated attackers to gain unauthorized access by exploiting a hardcoded string in the authentication mechanism. Attackers can bypass login controls to access administrative functions and sensitive switch configuration without valid credentials.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-798

Tecnología: No especificado

Publicado el: 2026-04-03



CVE-2017-20235

Descripción: ProSoft Technology ICX35-HWC version 1.3 and prior cellular gateways contain an authentication bypass vulnerability in the web user interface that allows unauthenticated attackers to gain access to administrative functions without valid credentials. Attackers can bypass the authentication mechanism in affected firmware versions to obtain full administrative access to device configuration and se...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-04-03



CVE-2017-20236

Descripción: ProSoft Technology ICX35-HWC versions 1.3 and prior cellular gateways contain an input validation vulnerability in the web user interface that allows remote attackers to inject and execute system commands by submitting malicious input through unvalidated fields. Attackers can exploit this vulnerability to gain root privileges and execute arbitrary commands on the device through the accessible w...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-04-03



CVE-2018-25236

Descripción: Hirschmann HiOS and HiSecOS products RSP, RSPE, RSPS, RSPL, MSP, EES, EESX, GRS, OS, RED, EAGLE contain an authentication bypass vulnerability in the HTTP(S) management module that allows unauthenticated remote attackers to gain administrative access by crafting specially formed HTTP requests. Attackers can exploit improper authentication handling to obtain the authentication status and privile...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-04-03



CVE-2021-4477

Descripción: Hirschmann HiLCOS OpenBAT and BAT450 products contain a firewall bypass vulnerability in IPv6 IPsec deployments that allows traffic from VPN connections to bypass configured firewall rules. Attackers can exploit this vulnerability by establishing IPv6 IPsec connections (IKEv1 or IKEv2) while simultaneously using an IPv6 Internet connection to circumvent firewall policy enforcement.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-284

Tecnología: No especificado

Publicado el: 2026-04-03



CVE-2016-20052

Descripción: Snews CMS 1.7 contains an unrestricted file upload vulnerability that allows unauthenticated attackers to upload arbitrary files including PHP executables to the snews_files directory. Attackers can upload malicious PHP files through the multipart form-data upload endpoint and execute them by accessing the uploaded file path to achieve remote code execution.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-04-04



CVE-2018-25254

Descripción: NICO-FTP 3.0.1.19 contains a structured exception handler buffer overflow vulnerability that allows remote attackers to execute arbitrary code by sending crafted FTP commands. Attackers can connect to the FTP service and send oversized data in response handlers to overwrite SEH pointers and redirect execution to injected shellcode.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-04-04



CVE-2019-25687

Descripción: Pegasus CMS 1.0 contains a remote code execution vulnerability in the extra_fields.php plugin that allows unauthenticated attackers to execute arbitrary commands by exploiting unsafe eval functionality. Attackers can send POST requests to the submit.php endpoint with malicious PHP code in the action parameter to achieve code execution and obtain an interactive shell.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-04-05



CVE-2019-25688

Descripción: Kados R10 GreenBee contains an SQL injection vulnerability that allows unauthenticated attackers to manipulate database queries by injecting SQL code through the menu_lev1 parameter. Attackers can send crafted requests with malicious SQL payloads in the menu_lev1 parameter to extract sensitive database information or modify database contents.

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-04-05



CVE-2019-25690

Descripción: Kados R10 GreenBee contains an SQL injection vulnerability that allows attackers to manipulate database queries by injecting SQL code through the mng_profile_id parameter. Attackers can send crafted requests with malicious SQL payloads in the mng_profile_id parameter to extract sensitive database information.

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-04-05



CVE-2019-25692

Descripción: Kados R10 GreenBee contains an SQL injection vulnerability that allows attackers to manipulate database queries by injecting SQL code through the 'id_to_modify' parameter. Attackers can send crafted requests with malicious SQL statements in the id_to_modify field to extract sensitive database information or modify data.

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-04-05



CVE-2019-25694

Descripción: Kados R10 GreenBee contains an SQL injection vulnerability that allows unauthenticated attackers to manipulate database queries by injecting SQL code through the user2reset parameter. Attackers can send crafted requests with malicious SQL payloads to extract sensitive database information or modify data.

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-04-05



CVE-2019-25696

Descripción: Kados R10 GreenBee contains an SQL injection vulnerability that allows attackers to manipulate database queries by injecting SQL code through the language_tag parameter.

Attackers can submit malicious SQL statements in the language_tag parameter to extract sensitive database information or modify data.

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-04-05



CVE-2019-25698

Descripción: Kados R10 GreenBee contains an SQL injection vulnerability that allows attackers to manipulate database queries by injecting SQL code through the id_to_delete parameter. Attackers can send crafted requests with malicious SQL statements in the id_to_delete field to extract or modify sensitive database information.

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-04-05



CVE-2019-25700

Descripción: Kados R10 GreenBee contains an SQL injection vulnerability that allows attackers to manipulate database queries by injecting SQL code through the sort_direction parameter.

Attackers can submit malicious SQL statements in the sort_direction parameter to extract sensitive database information or modify data.

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-04-05



CVE-2019-25702

Descripción: Kados R10 GreenBee contains an SQL injection vulnerability that allows attackers to manipulate database queries by injecting SQL code through the id_project parameter. Attackers can send crafted requests with malicious SQL statements in the id_project parameter to extract sensitive database information or modify data.

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-04-05



CVE-2019-25704

Descripción: Kados R10 GreenBee contains an SQL injection vulnerability that allows attackers to manipulate database queries by injecting SQL code through the filter_user_mail parameter. Attackers can send crafted requests with malicious SQL statements to extract sensitive database information or modify data.

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-04-05



CVE-2026-26263

Descripción: GLPI is a free asset and IT management software package. From 11.0.0 to before 11.0.6, an unauthenticated time-based blind SQL injection exists in GLPI's Search engine. This vulnerability is fixed in 11.0.6.

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-04-06



CVE-2026-35022

Descripción: Anthropic Claude Code CLI and Claude Agent SDK contain an OS command injection vulnerability in authentication helper execution where helper configuration values are executed using shell=true without input validation. Attackers who can influence authentication settings can inject shell metacharacters through parameters like apiKeyHelper, awsAuthRefresh, awsCredentialExport, and gcpAuthRefresh t...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-04-06



CVE-2026-0740

Descripción: The Ninja Forms - File Uploads plugin for WordPress is vulnerable to arbitrary file uploads due to missing file type validation in the 'NF_FU_AJAX_Controllers_Uploads::handle_upload' function in all versions up to, and including, 3.3.26. This makes it possible for unauthenticated attackers to upload arbitrary files on the affected site's server which may make remote code execution possible. Not...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-04-07



CVE-2021-4473

Descripción: Tianxin Internet Behavior Management System contains a command injection vulnerability in the Reporter component endpoint that allows unauthenticated attackers to execute arbitrary commands by supplying a crafted objClass parameter containing shell metacharacters and output redirection. Attackers can exploit this vulnerability to write malicious PHP files into the web root and achieve remote co...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-04-07



CVE-2026-22679

Descripción: Weaver (Fanwei) E-cology 10.0 versions prior to 20260312 contain an unauthenticated remote code execution vulnerability in the /papi/esearch/data/devops/dubboApi/debug/method endpoint that allows attackers to execute arbitrary commands by invoking exposed debug functionality. Attackers can craft POST requests with attacker-controlled interfaceName and methodName parameters to reach command-exec...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-04-07



CVE-2026-20889

Descripción: A heap-based buffer overflow vulnerability exists in the x3f_thumb_loader functionality of LibRaw Commit d20315b. A specially crafted malicious file can lead to a heap buffer overflow. An attacker can provide a malicious file to trigger this vulnerability.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-190

Tecnología: No especificado

Publicado el: 2026-04-07



CVE-2026-20911

Descripción: A heap-based buffer overflow vulnerability exists in the HuffTable::initval functionality of LibRaw Commit 0b56545 and Commit d20315b. A specially crafted malicious file can lead to a heap buffer overflow. An attacker can provide a malicious file to trigger this vulnerability.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-131

Tecnología: No especificado

Publicado el: 2026-04-07



CVE-2026-21413

Descripción: A heap-based buffer overflow vulnerability exists in the `lossless_jpeg_load_raw` functionality of LibRaw Commit 0b56545 and Commit d20315b. A specially crafted malicious file can lead to a heap buffer overflow. An attacker can provide a malicious file to trigger this vulnerability.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-129

Tecnología: No especificado

Publicado el: 2026-04-07



Resumen del Reporte

CVEs analizados: 54

Promedio CVSS: 9.02

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☹

